MSCA 560: DISTRIBUTED SYSTEMS & NETWORK SECURITY

# Validating Automated Post-Quantum End-to-End Tunnels

Experimental Replication & Practical Network Analysis of PQConnect

**Sterling H. Garrett**
M.S. Cybersecurity Assurance | School of Applied Computational Sciences, Meharry Medical College

Faculty: Prof. Firdous Kausar
NDSS 2025 Paper Reproduction

THREAT LANDSCAPE

# Harvest Now, Decrypt Later (HNDL)

### Adversary Strategy

Bulk interception of today's encrypted network traffic for decryption once quantum hardware matures.

### High-Value Targets

Decade-long secrets: hospital records, clinical data, supply chain systems, and enterprise credentials.

### Immediate Urgency

Cryptographic transition cannot wait for universal quantum computer availability.




Key Takeaway: Confidentiality must be fortified at the wire level today to prevent retroactive decryption.

OPERATIONAL REALITY

# The Application Upgrade Bottleneck

### Code Refactoring

PQ-TLS requires rewriting and re-certifying every enterprise daemon and custom microservice.

High deployment friction

### Implementation Flaws

Extensive CVE history: flawed hostname validation, buffer over-reads, and broken certificate checks.

Expanded attack surface

### Non-Web Protocols

Crucial enterprise protocols (SMTP, LDAP, IoMT medical telemetry) lack straightforward PQ-TLS paths.

Legacy operational gaps

Core Question: Can we secure the network layer directly, avoiding application-level modifications?

ARCHITECTURAL COMPARISON

# Standard VPNs vs. Automated Tunneling

| Architecture Dimension | Traditional Proxy VPN | Mesh VPN (WireGuard/IPsec) | PQConnect (NDSS 2025) |
|---|---|---|---|
| **Application Transparency** | Yes (Network layer) | Yes (Network layer) | **Yes (Zero modifications)** |
| **End-to-End Encryption** | No (Terminates at proxy) | Yes (Peer-to-peer) | **Yes (Client to server)** |
| **Peer Discovery & Setup** | Manual Gateway Config | Manual Per-Peer Config | **100% Automated via DNS** |
| **Post-Quantum KEM Baseline** | Rare / Experimental | Optional Extensions | **Native Hybrid McEliece + SNTRUP** |

Design Insight: PQConnect combines VPN transparency with automatic web-scale peer discovery.

MECHANISMS

# Zero-Probe DNS Peer Discovery

### STEP 1: DNS EMBEDDING

Server publishes its public key digest inside a standard DNS CNAME record: pq1[52-char-hash].domain.tld

### STEP 2: LOCAL PACKET FILTERING

Linux client daemon uses netfilter to inspect incoming DNS responses and detect the pq1 announcement prefix.

### STEP 3: LOCAL ADDRESS REWRITING

The real public IP is substituted with a virtual local address (10.59.0.2).
Outbound application sockets route directly to the virtual tunnel interface (pqccli0).

**Wire Inspection: Non-PQ vs. PQ Target**

```
// Standard Query (Passes unhindered)
Query: www.ndss-symposium.org A
Resp: 104.18.8.22 [UNTOUCHED]

// PQConnect Target (Intercepted)
Query: www.pqconnect.net A
CNAME: pq1u1hy1ujsuk...pqconnect.net
Rewritten IP: 10.59.0.2 → pqccli0
```

Zero extra probe datagrams generated for legacy servers.

Engineering Merit: Client discovers server capabilities passively without active port scanning or probing.

CRYPTOGRAPHIC FOUNDATION

# 4-Layer Nested Key Encapsulation (KEX)

LAYER 1 (OUTER)

### Classic McEliece

mceliece6960119

Code-based; unbroken since 1978. Conservative long-term quantum security.

LAYER 2

### X25519 Static

Static-Ephemeral ECDH

Classical security foundation against unforeseen post-quantum design flaws.

LAYER 3

### X25519 Ephemeral

Ephemeral-Ephemeral ECDH

Classical ephemeral forward secrecy protecting internal handshake secrets.

LAYER 4 (INNER)

### NTRU Prime

sntrup761 Ephemeral

Fast lattice-based post-quantum key exchange providing quantum forward secrecy.

Defense-in-Depth: Nesting forces attackers to break layers sequentially rather than in parallel.

NETWORK ENGINEERING SOLUTIONS

# Overcoming the 1 MB Public Key Challenge

## 3-Tier Merkle Key Streaming over UDP

The 1,047,319-byte Classic McEliece public key is broken into 910 UDP-sized leaf chunks.

**Chunk Authentication:** Intermediate nodes (1152 bytes) fit standard MTUs.

**3-RTT Transfer Bound:** Root hash in DNS verifies tree top-down instantly.

**Anti-Amplification:** Key requests are zero-padded 1:1 to prevent DDoS reflection.

## Ciphertext Amortization

The 1MB transfer penalty is incurred exactly once per server during initial setup.

> McEliece Ciphertext: 194 bytes
>
> Clients precompute and cache 194-byte ciphertexts, enabling 0-RTT tunnel rebuilds indefinitely.

Bandwidth Analysis: In typical enterprise workflows, initial setup overhead drops below 1% of total session bytes.

SESSION SECURITY

# Two-Dimensional Ratchet & Key Erasure

### Vertical Dimension: Epochs

Advances every 30 seconds to generate a fresh root key, establishing strong forward secrecy boundaries.

Root key rotation = 30s

### Horizontal Dimension: Chains

Derives a unique one-time ChaCha20 key for every transmitted packet within the active epoch.

One-time key per packet

### Time-Based Key Erasure

Sender deletes keys immediately upon use. Receiver deletes keys upon consumption, or hard cap at 120s.

Max retention = 120s

Safety Margin: Tolerates out-of-order and delayed packets up to 90s without extending key exposure windows.

FORMAL MATHEMATICAL PROOFS

# Handshake Verification via Tamarin Prover

## Symbolic Analysis in Dolev-Yao Model

Evaluated against active network adversaries capable of modifying packets and revealing long-term keys.

**Liveness:** Proves the 0-RTT initiation sequence terminates successfully.

**PQ Forward Secrecy:** Secrecy holds even if classical keys and static McEliece keys leak.

**Authentication:** Proves mutual initiator-to-responder identity binding.

```
$ tamarin-prover proofs/handshake.spthy --prove

lemma 0_RTT_executable:
  verified (13 steps)

lemma 0_RTT_FS_confidential:
  verified (24 steps)

lemma responder_client_auth:
  verified (7 steps)
```

Verification Summary: The mathematical model eliminates handshake deadlocks, replay flaws, and structural weaknesses.

COURSE DELIVERABLE (PATH 4)

# Experimental Reproduction Testbed

STAGE 1

### DNS Interception

Query test server: `dig www.pqconnect.net`

Confirm public IP (131.155.69.126) rewrites to virtual address 10.59.0.2 via netfilter.

STAGE 2

### Encapsulation Check

Fetch HTTP: `wget -O test.html http://www.pqconnect.net`

Verify with tcpdump that raw TCP 80 never appears; traffic travels as UDP port 42424 ciphertext.

STAGE 3

### Non-PQ Fallback

Query legacy host: `testwithout.pqconnect.net`

Confirm traffic passes straight through as standard TCP without extra probes or latency penalties.

Reproduction Goals: Validate transparent application protection and clean fallback on unmodified Linux hosts.

PRACTITIONER ANALYSIS

# Healthcare and Enterprise Network Considerations

### 1. MTU & Packet Overhead (+56 Bytes)

Adding 56 bytes to 1500-byte Ethernet frames causes IP fragmentation unless edge routers enforce MSS clamping (e.g., 1404 bytes) or jumbo frames.

### 2. Encrypted DNS Conflict (DoH/DoT)

Browsers using external DNS-over-HTTPS bypass netfilter rewriting. Enterprise canary blocking (use-application-dns.net) is required.

### 3. Stateful Firewall Dynamics

30-second epoch rotations create short-lived UDP state bindings, requiring tailored NAT timeout configurations on corporate firewalls.



Operational Assessment: Protocol mechanics are sound, but production rollout requires disciplined network-edge tuning.

CONCLUSION & DISCUSSION

# Project Timeline & Open Discussion

[COMPLETED]

**Literature & Formal Proofs**

NDSS paper review, Tamarin model verification, and repo setup.

[CURRENT STAGE]

**Testbed Execution**

Client daemon deployment, live traffic capture, and fallback validation.

[DUE NOV 12]

**Final IEEE Report**

6–8 page conference paper incorporating presentation feedback.

## Thank You — Questions & Discussion

GitHub: https://github.com/Shgarrett/msca560-pqconnect-evaluation